PHASE 1 INTERNSHIP REPORT

Practical Web Security

Web Application Penetration Testing (WAPT/VAPT)

IqraSec Academy

Name	Pradheepa M
Internship	IqraSec Academy: Web Application Penetration Testing (WAPT/VAPT)
Phase	Phase 1: Practical Web Security
Date	October 21, 2026

1. Executive Summary

During Phase 1 of the IqraSec WAPT/VAPT internship, I established a strong foundation in web application security by combining theoretical learning with hands-on practical application. I built an isolated penetration testing lab using **Kali Linux** as the attacker machine and **Metasploitable 2** as the vulnerable target.

By using industry-standard tools such as **Burp Suite** and **Nmap**, I performed reconnaissance, analyzed HTTP traffic and exploited common web vulnerabilities. I also completed multiple Apprentice to Practitioner-level labs on the PortSwigger Web Security Academy and studied core concepts through TryHackMe. This report documents my key learnings, methodologies and practical takeaways from these exercises.

Attacker machine	Kali Linux
Target machine	Metasploitable 2
Tools	Burp Suite, Nmap, Firefox
Platforms	PortSwigger Web Security Academy, TryHackMe
Vulnerabilities covered	XSS (reflected, stored, DOM-based), SQL Injection, IDOR

2. Task 1: Web Basics

> **Learning Objective:** Understand the fundamentals of HTTP/HTTPS, request/response cycles, headers, cookies and sessions.

What I Learned and Practiced

- **HTTP Traffic Analysis:** I learned how web applications communicate using GET and POST methods. By configuring Burp Suite as an intercepting proxy and routing Firefox traffic through it, I captured raw HTTP requests.
- **Headers and Sessions:** I analyzed the anatomy of a request, focusing on the Host, User-Agent and Cookie headers. Session IDs are typically stored in cookies to maintain a user's authentication state across multiple requests. I practiced modifying the User-Agent header in Burp Repeater to understand how easily client-side data can be spoofed if the server does not validate it.
- **TryHackMe:** I reinforced these concepts by completing the theoretical modules on web application basics and HTTP in detail.

3. Task 2: Reconnaissance

> **Learning Objective:** Master technology identification, directory discovery and information gathering.

What I Learned and Practiced

- **Network Scanning:** Using Nmap on Kali Linux, I performed a comprehensive scan (`-sV -sC -p-`) against the Metasploitable 2 target. I learned to identify open ports and the services running on them, for example FTP on 21, SSH on 22, HTTP on 80 and MySQL on 3306.
- **Attack Surface Mapping:** Once the HTTP service was identified, I used browser-based discovery to map the web application. I located critical directories such as `/dvwa` (Damn Vulnerable Web App), `/mutillidae` and `/phpmyadmin`. Manual discovery and understanding the application's structure is just as important as automated scanning.
- **TryHackMe:** I studied the methodologies of content discovery, including the use of wordlists for directory brute-forcing.

4. Task 3: Authentication, Session and Access Control (IDOR)

> **Learning Objective:** Understand flaws in authentication, session management and Insecure Direct Object References (IDOR).

What I Learned and Practiced

- **Access Control Concepts:** IDOR vulnerabilities occur when an application exposes internal object references (such as user IDs or file names) and fails to verify whether the requesting user is authorized to access them.
- **Privilege Escalation:** I learned the difference between *horizontal* privilege escalation (accessing another user's data at the same privilege level) and *vertical* privilege escalation (gaining administrative rights).
- **Practical Adaptation:** The specific TryHackMe IDOR room was restricted to Premium subscribers, so I applied the learning objectives through alternative free resources and PortSwigger labs. I focused on manipulating parameters (for example, changing `id=10` to `id=11`) in Burp Suite to test for authorization bypasses.

5. Task 4: Common Web Vulnerabilities

> **Learning Objective:** Identify, exploit and understand the impact of common vulnerabilities such as SQL Injection and Cross-Site Scripting (XSS).

What I Learned and Practiced

Cross-Site Scripting (PortSwigger Labs). I solved four distinct PortSwigger labs, progressing from Apprentice to Practitioner level:

- **Reflected and Stored XSS:** injecting `<script>alert(1)</script>` into unvalidated inputs, such as search bars or comment fields, can execute malicious JavaScript in a victim's browser.
- **DOM-based XSS:** I analyzed client-side JavaScript and learned how unsafe sinks (like `document.write`) combined with controllable sources (like `location.search`) create vulnerabilities. In the Practitioner lab, I broke out of an HTML `<select>` element context to execute the script.

SQL Injection (Local DVWA). On my local Metasploitable 2 lab, I practiced SQL Injection by entering the payload `' OR 1=1--` into the DVWA User ID field. This bypassed the login logic and dumped all user records from the database, demonstrating how poor input sanitization leads to database compromise.

6. Remediation and Secure Coding Practices

Through exploiting these vulnerabilities, I learned that prevention requires a defense-in-depth approach:

1. **Input Validation and Output Encoding:** never trust user input. Data must be strictly validated (using allowlists) and contextually encoded (HTML, JavaScript, attributes) before being rendered.
2. **Parameterized Queries:** to prevent SQL injection, developers must use prepared statements. User input should never be concatenated directly into SQL queries.
3. **Access Control:** server-side checks are mandatory. Never rely on client-side hiding of data or assume a user will not change an ID parameter in a URL.
4. **Content Security Policy (CSP):** a strong CSP acts as a safety net by restricting which scripts are allowed to execute on a page.

7. Conclusion and Key Learnings

Phase 1 of the IqraSec internship has been an excellent transition from theory to practice. I have moved beyond just reading about vulnerabilities to actively exploiting them in a safe, isolated environment. I am now comfortable navigating Burp Suite to intercept and manipulate traffic, using Nmap to enumerate targets, and understanding the mechanics of XSS and SQL Injection.

This hands-on practice has given me a hacker's mindset and a defender's understanding of secure coding. I feel fully prepared and excited to apply these skills to the practical, real-world-style WAPT project in Phase 2.

End of Report